

Reporte Ejecutivo

Gestión de Riesgos de Seguridad de la Información

Organización	Clínica Privada	Destinatario	Directorio de la Clínica
Alcance	Sistemas de información, datos e infraestructura crítica	Fecha	Septiembre 2026

1. Resumen ejecutivo

La clínica privada cuenta con **120 empleados** y atiende aproximadamente **800 pacientes diarios**. El análisis inicial identificó siete riesgos asociados principalmente a historias clínicas digitales, datos personales y de seguros, facturación, infraestructura y continuidad operativa.

La evaluación determinó **3 riesgos Críticos** y **4 riesgos Altos**, por lo que se recomienda priorizar acciones de mitigación sobre los eventos que puedan comprometer la confidencialidad de la información, la continuidad de la atención y la integridad de los datos.

7 Riesgos identificados	3 Riesgos Críticos	4 Riesgos Altos	3 Planes de acción
----------------------------	-----------------------	--------------------	-----------------------

2. Top 5 riesgos por nivel

La priorización se realizó mediante la matriz de **Probabilidad × Impacto**, utilizando una escala de 1 a 5. Los niveles corresponden a: Bajo (1–4), Medio (5–9), Alto (10–15) y Crítico (16–25).

ID	Riesgo	P	I	P×I	Nivel	Tratamiento
R01	Acceso no autorizado a historias clínicas digitales	4	5	20	CRÍTICO	Mitigar
R02	Ransomware sobre el sistema de historias clínicas	4	5	20	CRÍTICO	Mitigar
R04	Indisponibilidad del sistema de historias clínicas	4	5	20	CRÍTICO	Mitigar
R03	Pérdida o corrupción de historias clínicas digitales	3	5	15	ALTO	Mitigar
R05	Filtración de datos personales y médicos de pacientes	3	5	15	ALTO	Mitigar

3. Estado de los planes de acción

Se registraron tres planes de acción en SimpleRisk. Todos fueron **aceptados** y presentan un **avance inicial de 0%**, por lo que requieren seguimiento hasta verificar su implementación.

Riesgo	Plan	Vencimiento	Presupuesto	Estado
R02	Backups y recuperación	31/10/2026	\$0–\$100.000	Aceptado · 0%
R01	MFA y revisión de permisos	30/11/2026	\$0–\$100.000	Aceptado · 0%
R04	Redundancia y continuidad	31/12/2026	\$100.001–\$200.000	Aceptado · 0%

4. Recomendaciones prioritarias

- 1. Proteger el acceso a la información sensible.** Implementar MFA, principio de mínimo privilegio, revisión periódica de permisos y revocación inmediata de cuentas de personal desvinculado.
- 2. Fortalecer la recuperación ante ransomware y pérdida de datos.** Mantener copias protegidas, preferentemente offline o inmutables, verificar su integridad y realizar pruebas periódicas de restauración.

- **3. Aplicar defensa en profundidad.** La estrategia puede representarse mediante la analogía de los **tres cerditos**: una primera capa de prevención mediante controles de acceso, una segunda capa de detección mediante monitoreo y registros, y una tercera capa de recuperación mediante backups, redundancia y continuidad operativa.
- **4. Considerar las amenazas externas.** El ejemplo de **Caperucita Roja y el lobo feroz** permite representar que una organización debe asumir la existencia de amenazas externas y establecer controles antes, durante y después de un incidente, en lugar de depender de una única barrera.
- **5. Proteger la infraestructura crítica.** Incorporar redundancia eléctrica y de conectividad, UPS, monitoreo y procedimientos de contingencia. Los centros de datos nunca deberían ubicarse junto a cocinas ni debajo de lavamanos, piletas o piscinas, debido al riesgo combinado de incendio e inundación.
- **6. Mantener actualizado el análisis.** Revisar los riesgos y planes de acción periódicamente y ante cambios relevantes en sistemas, procesos, infraestructura o amenazas.

Conclusión para el Directorio

La gestión de riesgos debe mantenerse como un proceso continuo. La prioridad inmediata debe centrarse en proteger la información clínica sensible y asegurar la continuidad de los servicios esenciales. La implementación y seguimiento de los planes definidos permitirá mejorar progresivamente las capacidades de prevención, detección, respuesta y recuperación de la clínica.